

Manual 05 - AI Auditing and Assurance

CONTROLLED PUBLICATION QA CANDIDATE

Controlled source revision: d42b12447646993c54caade2b399efd4fb37f8d9 | Language: en | controlled assurance baseline and source watch retained.

Assurance boundary: This implementation manual does not establish auditor independence, professional competence, sufficient appropriate evidence, legal compliance, certification, conformity, or a formal audit opinion. Conclusions remain dependent on engagement-specific criteria, evidence, limitations, and human judgment.

Implementation paths and audit operating model

Manual 05 — AI Auditing and Assurance Implementation Paths

This implementation entry provides a proportional operating model for organizations conducting AI audit and assurance work. It does not change the truthfulness requirement: every conclusion must state what was examined, against which criteria, with what evidence, under which limitations, and by whom.

1. Select the assurance path

Essential

Use when AI scope is limited, organizational complexity is low, the audit team is small, or the engagement is an initial readiness/internal review. Minimum expectations:

- written mandate, objective, criteria, and scope;
- inventory of in-scope AI systems/use cases and accountable owners;
- documented evidence request and test plan;
- traceable findings and management responses;
- explicit evidence limitations and residual risk;
- remediation tracking and follow-up;
- reviewer/date/decision record.

Structured

Use when multiple AI systems, business units, regulatory obligations, suppliers, or higher-risk use cases are involved. Add:

- risk-based sampling and documented rationale;
- separation of design-effectiveness and operating-effectiveness testing;
- lifecycle and change-management testing;
- model/data/system lineage evidence;
- supplier and dependency assurance;
- human-oversight effectiveness testing;
- severity methodology and root-cause analysis;
- independent quality review before closure.

Enhanced

Use for high-impact, safety-relevant, highly regulated, externally assured, enterprise-scale, or complex agentic/Generative AI environments. Add:

- specialist technical testing and challenge;
- independent audit/assurance leadership where required;
- expanded sampling and population-quality controls;
- scenario, misuse, abuse, red-team, resilience, incident, and rollback evidence;
- cross-framework criteria mapping;

- executive/board escalation thresholds;
- formal remediation validation and recurrence analysis;
- retained evidence package capable of external scrutiny.

2. Route by risk and complexity

Manual 05 memory graphic 1

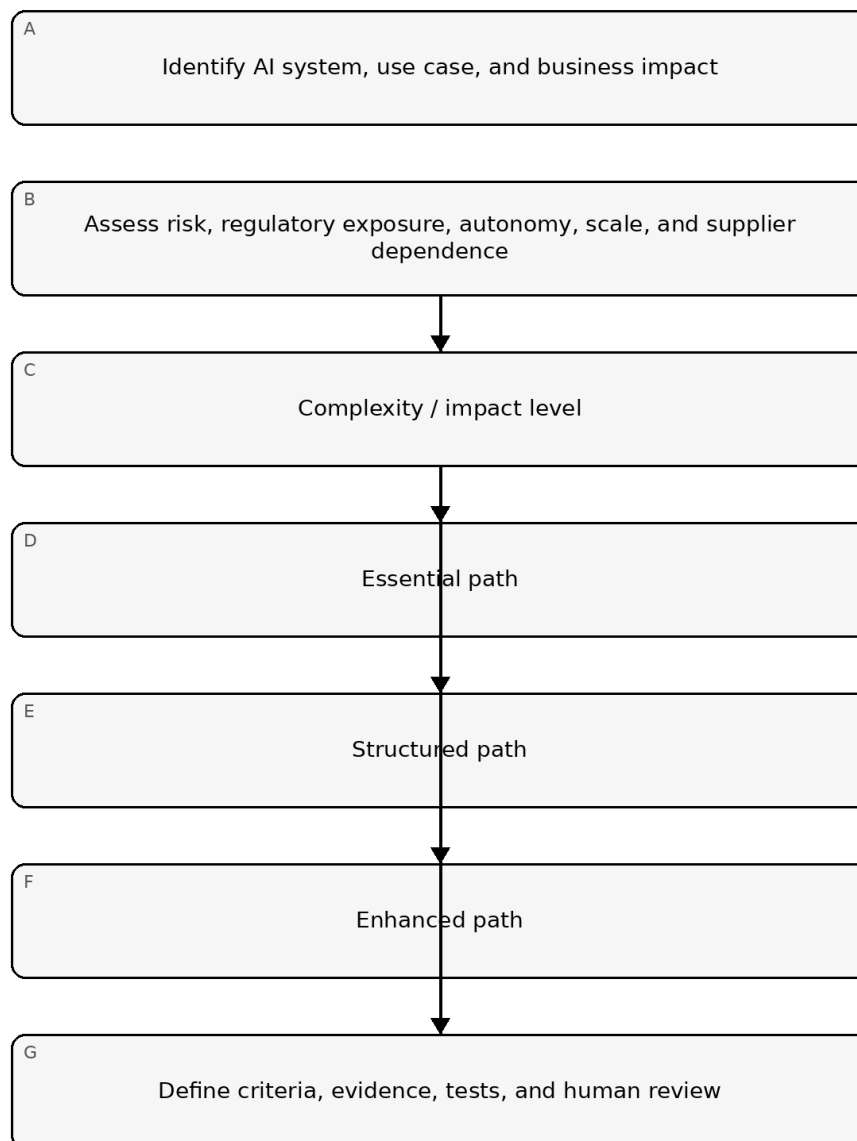


Figure 1. Implementation memory graphic

Accessible explanation: Start with the AI system or use case and evaluate impact, regulatory exposure, autonomy, organizational scale, and supplier dependence. Lower-complexity work follows Essential controls, moderate multi-system work follows Structured controls, and high-impact or regulated work follows Enhanced controls. Every path still requires defined criteria, evidence, tests, and human review.

3. Audit lifecycle

Stage 1 — Mandate and scope

Record the audit sponsor, authority, objective, intended users, independence considerations, systems/use cases, locations, lifecycle stages, suppliers, exclusions, time period, and reporting route. Scope exclusions must never be hidden when they could change how a reader interprets the result.

Stage 2 — Criteria and evidence plan

Criteria may include law, regulation, contractual obligations, organizational policy, approved risk appetite, internal controls, NIST guidance, ISO management-system requirements available under appropriate licensing, or other controlled requirements. Record source/version and whether each criterion is mandatory, voluntary, contractual, or internally adopted.

For each objective, define expected evidence, population, sample approach, test method, responsible tester, and expected conclusion type. Avoid vague tests such as “review governance.” State exactly what evidence would support or contradict the control objective.

Stage 3 — Fieldwork and testing

Test relevant combinations of:

- governance and accountability;
- AI inventory and use-case approval;
- risk and impact assessment;
- data provenance, quality, privacy, and access controls;
- model/system development and evaluation;
- Generative AI and agentic-AI guardrails;
- security threats and mitigations;
- human oversight and escalation;
- transparency and user communication;
- supplier/vendor dependencies;
- logging, monitoring, incidents, rollback, and decommissioning;
- policy exceptions and risk acceptance.

Differentiate documentary evidence from operational evidence. A policy alone does not prove implementation; a configuration screenshot alone does not prove sustained operation.

Stage 4 — Findings and severity

A controlled finding should contain:

1. Criteria — what requirement/control expectation applies.
2. Condition — what evidence shows actually occurred.
3. Cause — why the gap exists, when supportable.
4. Risk/impact — why the condition matters.
5. Evidence — traceable supporting records.
6. Scope/limitation — population/sample/time boundaries.
7. Severity — using the approved methodology.
8. Owner — accountable management owner.

Do not upgrade an observation into a confirmed failure without adequate evidence. Do not downgrade a confirmed high-risk condition merely because remediation is planned.

Stage 5 — Management response

Capture agreement/disagreement, rationale, accountable owner, remediation action, target date, risk acceptance/escalation where applicable, and dependencies. Management response does not erase the original finding.

Stage 6 — Remediation validation

Validate corrective action against the finding and root cause. Evidence should demonstrate that the changed control is implemented and, where appropriate, operating for a sufficient period. Record residual risk and any partial remediation honestly.

Stage 7 — Closure and follow-up

Close only when the approved closure criteria are satisfied. Preserve unresolved items, exceptions, evidence links, reviewer decisions, and recurrence indicators. Material system, model, data, supplier, legal, or source changes can trigger reassessment.

Manual 05 memory graphic 2

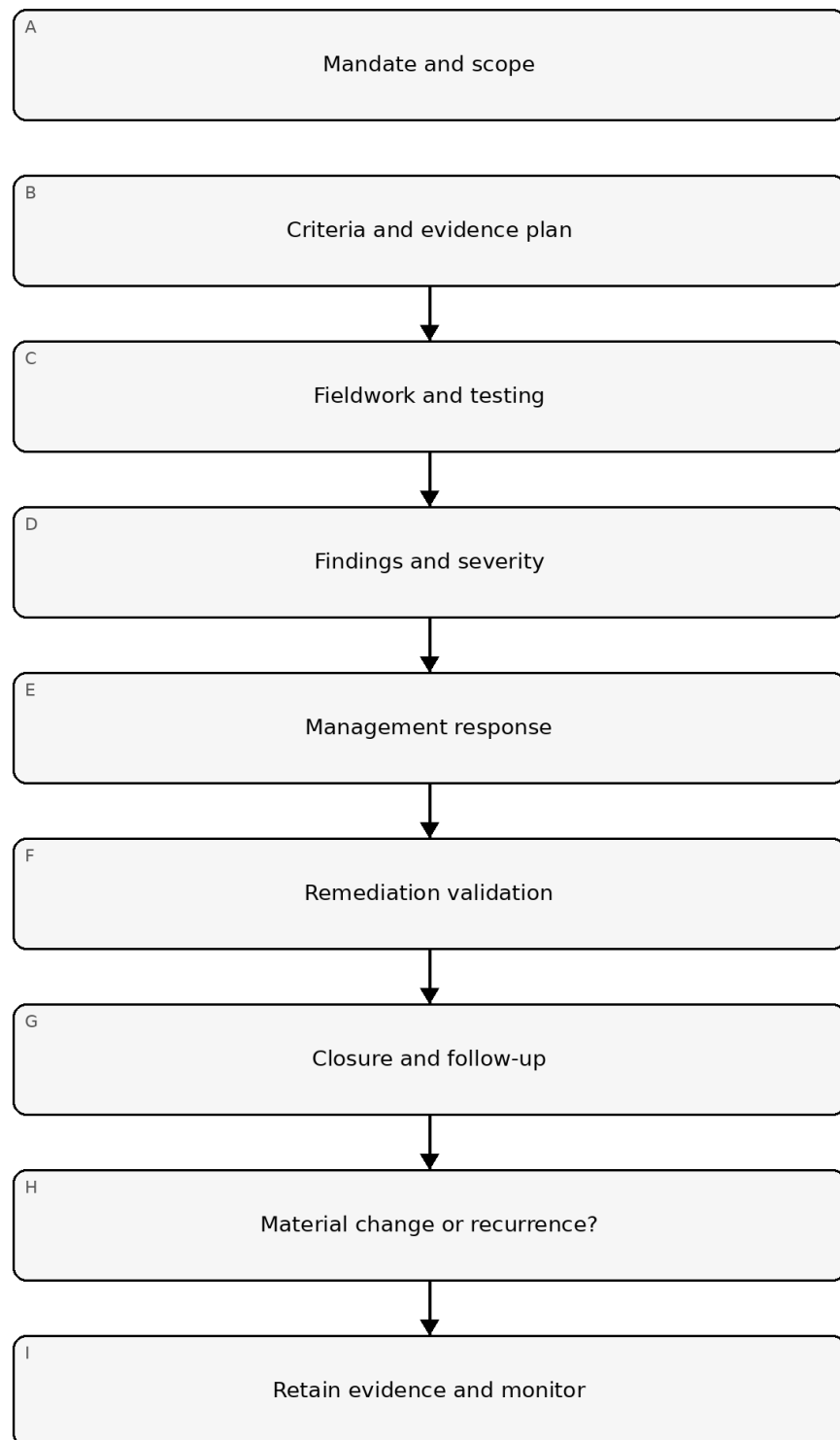


Figure 2. Implementation memory graphic

Accessible explanation: The audit starts with an authorized scope, proceeds through criteria/evidence planning, fieldwork, findings, management response, remediation validation, and closure. A material change or recurrence returns the work to a new scoped assessment rather than silently relying on old evidence.

4. Evidence sufficiency and sampling

The engagement should define evidence sufficiency before conclusions are finalized. Consider relevance, reliability, completeness, timeliness, source independence, population quality, reproducibility, and contradictory evidence.

Sampling should record:

- population definition;
- population completeness checks;
- sample size and selection method;
- risk-based or statistical rationale as applicable;
- exceptions found;
- whether exceptions require expanded testing;
- conclusion limitations.

For AI systems, evidence may include system cards, model cards, impact assessments, risk registers, evaluation results, red-team reports, prompts/test suites, guardrail configurations, logs, incident tickets, change records, access records, supplier attestations, contracts, DPIAs, approvals, monitoring metrics, and user-feedback evidence. The existence of an artifact is not automatically proof that the control is effective.

5. Technical and human testing

AI assurance frequently requires both technical evidence and human-process evidence. The engagement should determine whether it has the competence to test:

- model/system behavior under expected and adverse conditions;
- hallucination/confabulation risk where relevant;
- content provenance and integrity;
- bias/fairness controls where applicable;
- security and privacy controls;
- prompt injection and tool-use boundaries;
- agent permissions and authorization;
- data leakage paths;
- monitoring and incident detection;
- stop, rollback, containment, and decommissioning mechanisms.

When competence is unavailable, record the limitation or use a qualified specialist. Do not imply testing that was not performed.

6. Independence, competence, and conflicts

Document who designed the control, who operates it, who tested it, and who reviews the conclusion. Internal audit, second-line assurance, readiness assessment, and external certification contexts have different independence expectations. The manual must not collapse those distinctions.

Conflict-of-interest controls should address self-review, management participation, vendor incentives, implementation-team involvement, and pressure to alter severity or conclusions.

7. Cross-framework assurance

A single AI control may support multiple criteria, but mapping does not prove equivalence. Crosswalks should preserve the original requirement meaning, applicability, scope, and evidence expectations. Examples of controlled source families include ISO/IEC 42001, ISO 19011, ISO/IEC 42006, NIST AI RMF, NIST AI 600-1, and NIST SP 800-53A.

Where a proprietary standard is involved, the repository may summarize original implementation concepts but must not reproduce copyrighted requirements beyond permitted use.

8. Reporting model

The report should separate:

- executive conclusion;
- engagement objective and scope;
- criteria;

- methodology and sampling;
- confirmed findings;
- observations and recommendations;
- evidence limitations;
- management responses;
- unresolved disputes;
- residual risk;
- follow-up requirements;
- assurance boundary.

A readiness review must not be labeled as certification. Internal QA must not be labeled as independent audit assurance. Repository QA must not be presented as evidence that an organization complies with a law, framework, or standard.

9. Evidence-to-decision chain

Manual 05 memory graphic 3

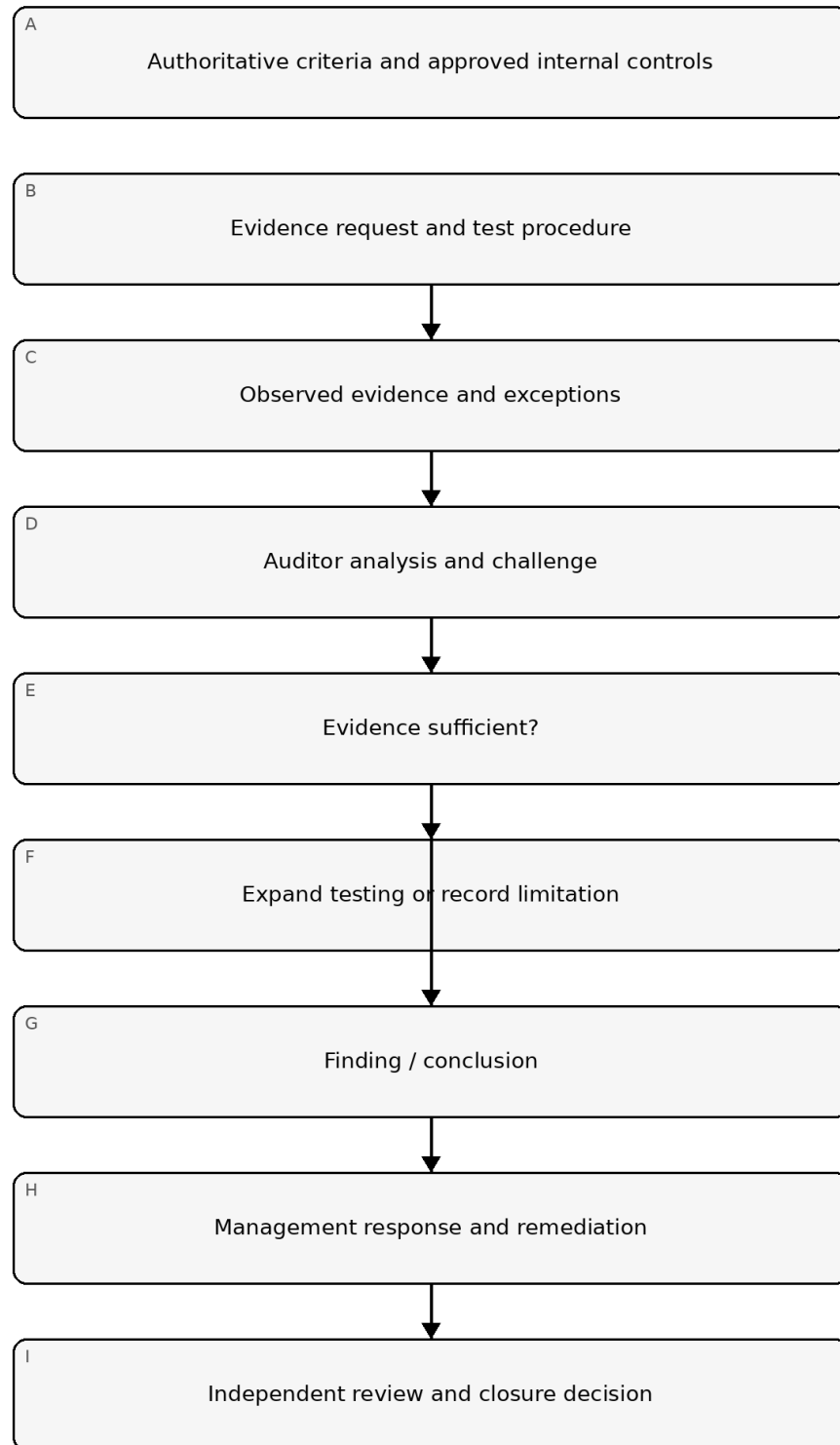


Figure 3. Implementation memory graphic

Accessible explanation: Conclusions originate from controlled criteria, planned tests, and observed evidence. If evidence is insufficient, testing expands or the limitation is recorded. Only sufficiently supported conclusions proceed to management response, remediation, independent review, and closure.

10. Minimum release evidence for this manual

Before Manual 05 can be published, the project must retain:

- controlled English source master;
- source verification and source-status record;
- editorial/technical review evidence;
- es-419 and pt-BR semantic-review evidence;
- graphic accessibility evidence;
- DOCX/PDF processing evidence;
- page-level QA;
- security/repository audit;
- checksums and release manifest;
- reviewer/date/decision records;
- final human release approval.

Passing automated checks is supporting evidence only. Human judgment remains required where the control framework says it is required.

Controlled 32-chapter manual

Chapter 01 — Audit mandate and objective

Every AI audit begins with a documented mandate. The mandate identifies who requested the work, why the audit is being performed, what decision the results will support, the authority of the audit team, and any restrictions on access or reporting.

The audit objective should be written as a testable statement. “Review AI governance” is too broad; “determine whether production AI systems above the organization’s high-risk threshold have approved owners, current risk assessments, release evidence, monitoring, and documented residual-risk acceptance” is auditable.

Chapter 02 — Criteria and assurance boundary

Audit criteria must be identified before fieldwork. Criteria may come from law, regulation, contract, internal policy, approved standards, management commitments, control frameworks, or defined operating requirements.

The audit record must distinguish mandatory criteria from guidance and professional-practice references. ISACA AAIA is used here as a professional-practice reference for capability and audit-domain coverage; it is not law, regulation, an ISO standard, organizational certification, or an audit opinion.

Chapter 03 — Scope and system boundary

The scope should identify the AI systems, business processes, legal entities, locations, environments, time period, suppliers, datasets, models, interfaces, and lifecycle stages included. Exclusions require rationale.

AI audits should decompose systems into relevant components: data, model, prompts, retrieval, tools, identities, infrastructure, monitoring, human review, suppliers, and change processes. A model-only scope may miss material risk in orchestration or downstream actions.

Chapter 04 — Independence, competence, and conflicts

The audit lead should assess whether the team has sufficient independence and competence for the objective. High-impact technical testing may require security, privacy, data science, model-risk, legal, accessibility, safety, or domain specialists.

Conflicts should be disclosed when auditors designed, implemented, approved, or materially operated the control being evaluated. Where full organizational independence is impossible, the limitation and compensating review should be documented.

Chapter 05 — Audit planning and risk prioritization

Planning should prioritize areas where control failure could create material harm or where evidence quality is uncertain. Inputs may include prior findings, incidents, risk registers, regulatory obligations, model criticality, data sensitivity, autonomy, supplier dependence, and recent changes.

The audit plan should state procedures, evidence sources, sampling approach, technical tests, interviews, responsible auditors, timing, and expected deliverables.

Chapter 06 — Evidence strategy and sufficiency

Evidence must be relevant to the audit criterion and reliable enough to support the conclusion. Policies demonstrate design intent; they do not prove operation. Screenshots show a point in time; they may not prove sustained operation. Vendor assertions may support a conclusion but should be corroborated when supplier risk is material.

Evidence should be evaluated for relevance, reliability, completeness, timeliness, reproducibility where appropriate, and independence from the control owner.

Chapter 07 — Sampling and population definition

Sampling starts by defining the population. Examples include all production AI systems, all high-risk use cases, all model releases in a period, all critical suppliers, or all incidents meeting a severity threshold.

The sampling method should reflect the audit objective and risk. Judgmental sampling may target high-risk items; statistical techniques may be appropriate for homogeneous populations. Sample limitations and untested portions of the population must be disclosed.

Chapter 08 — Audit lifecycle and fail-closed quality gates

The controlled audit lifecycle is:

9. mandate and scope;
10. criteria and evidence plan;
11. fieldwork and testing;
12. findings and severity;
13. management response;
14. remediation validation;
15. closure and follow-up.

Quality gates fail closed when required evidence is unavailable, independence concerns are unresolved, testing is incomplete, reviewer comments remain open, material scope changes invalidate procedures, or a required human approval is missing.

Automated repository QA supports consistency of the manual package; it does not replace auditor judgment or human release approval.

Chapter 09 — Governance and risk audit procedures

Auditors should test whether AI governance operates beyond policy language. Procedures should verify accountable ownership, risk classification, approval authority, escalation, exception handling, and periodic review for sampled systems.

Evidence may include inventories, risk records, committee decisions, release approvals, monitoring reports, and change records.

Chapter 10 — AI operations audit procedures

Operational testing should evaluate deployment, monitoring, incident handling, access, change control, fallback, and retirement processes. The auditor should trace selected systems from approved design through current production state to determine whether the deployed configuration matches the evidence supporting release.

Chapter 11 — Data governance audit procedures

Data-related testing should address provenance, classification, permitted use, access, retention, transformation, quality controls, privacy restrictions, and deletion where applicable.

Where AI systems depend on retrieval or vector stores, the auditor should test how content is admitted, updated, removed, and protected from unauthorized access or manipulation.

Chapter 12 — Model and system testing

Audit testing should distinguish management's own evaluation from independent audit procedures. The audit team may inspect test design, reproduce selected tests, challenge assumptions, perform targeted technical procedures, or engage specialists.

Testing should be linked to defined criteria and risks rather than performed only because a tool is available.

Chapter 13 — Human oversight and decision controls

Auditors should determine whether required human review is actually possible and evidenced. Procedures may examine reviewer competency, available context, escalation authority, time pressure, override records, approval logs, and whether repeated overrides indicate control weakness.

Chapter 14 — Third-party and component assurance

Supplier assurance should evaluate the evidence relied upon for external models, hosting, APIs, datasets, tools, and other material components. Auditor procedures should consider contract terms, independent reports, security evidence, change notifications, incident history, data practices, and concentration or exit risk.

A completed questionnaire should not be treated as equivalent to independently supported assurance.

Chapter 15 — Technical audit tools and automation

Automated tools can support inventory analysis, configuration checks, log review, test execution, sampling, evidence correlation, and anomaly detection. Tool output remains audit evidence that must be understood, validated, and interpreted.

Auditors should document tool version, configuration, input population, limitations, and how exceptions were investigated.

Chapter 16 — Workpaper discipline

Each significant conclusion should be traceable to the criterion, procedure, evidence, result, preparer, and reviewer. Workpapers should distinguish observed facts, management representations, auditor analysis, assumptions, and unresolved limitations.

Material reviewer comments must be resolved or explicitly carried into the report before the audit is closed.

Chapter 17 — Finding development

A finding should connect criterion, condition, cause, consequence, and evidence. Vague statements such as “governance should improve” are not sufficient. The finding should identify what requirement or approved expectation was not met, what was observed, why it matters, and what evidence supports the conclusion.

Chapter 18 — Severity and prioritization

Severity should reflect consequence and likelihood in context. Factors may include safety, security, privacy, regulatory, financial, operational, customer, workforce, and reputational effects.

The audit team should use a consistent severity method and document when professional judgment overrides a mechanical score.

Chapter 19 — Root cause analysis

Root cause analysis should distinguish immediate failure from systemic cause. Examples include unclear ownership, ineffective approval design, inadequate testing, weak supplier governance, poor change control, missing competencies, or incentives that bypass controls.

Remediation aimed only at the visible symptom should not be represented as root-cause correction.

Chapter 20 — Management response

Management responses should state agreement or disagreement, planned action, owner, target date, and any accepted residual risk. Disagreement should be supported by evidence or rationale rather than simply removing the finding from the report.

Chapter 21 — Residual risk and acceptance

When remediation does not fully eliminate risk, the remaining exposure should be documented and accepted by an authority appropriate to its significance. The auditor should not silently convert an unresolved control gap into an acceptable state.

Chapter 22 — Reporting limitations

Reports should state scope, period, criteria, procedures, material limitations, unresolved evidence gaps, and the intended meaning of the conclusion. Readers should be able to distinguish an internal readiness review, advisory assessment, audit, certification activity, or other assurance engagement.

Chapter 23 — Remediation validation

Closure requires evidence that corrective action was implemented and, where appropriate, that it operates effectively. Validation may include document review, configuration inspection, retesting, sample testing, interviews, or observation. Management assertion alone should not close a material finding when objective evidence is reasonably available.

Chapter 24 — Follow-up and recurrence

Follow-up should consider whether findings recur, whether similar systems have the same weakness, and whether remediation introduced new risk. Repeated findings may indicate a governance or control-system problem rather than isolated execution failure.

Chapter 25 — Quality review

Before reporting, a reviewer should confirm that significant conclusions are supported by sufficient evidence, scope changes are documented, findings are internally consistent, and unresolved review comments are visible.

High-impact engagements should use reviewer independence proportionate to risk.

Chapter 26 — Report structure

Reports should present objective, scope, criteria, methods, overall conclusion, findings, management responses, limitations, and follow-up requirements. Executive summaries should not omit material qualifications that affect interpretation.

Chapter 27 — Assurance language

Assurance language must match the engagement performed. Readiness assessments, advisory reviews, internal audits, external audits, certification activities, and technical tests are not interchangeable.

The report should avoid implying certification, legal compliance, or formal audit opinion unless the engagement legitimately provides that result.

Chapter 28 — Corrective-action governance

Open findings should be tracked to accountable owners and dates. Extensions should be approved and justified. High-severity overdue actions should escalate to the appropriate risk authority rather than remaining indefinitely open.

Chapter 29 — Audit evidence retention

Evidence and workpapers should be retained according to applicable policy, legal, contractual, and professional requirements. Access should be restricted because AI audit evidence can contain sensitive architecture, data, security findings, model information, or personal information.

Chapter 30 — Continuous assurance and monitoring

Where risk warrants, periodic audit can be supplemented by continuous or recurring control indicators. Automated monitoring should have defined ownership, thresholds, exception handling, and validation.

Continuous monitoring does not remove the need for human interpretation and periodic reassessment of whether the indicators remain meaningful.

Chapter 31 — Audit program maturity

A mature AI audit program maintains a system inventory, risk-informed audit universe, reusable workpapers, competency plans, specialist access, consistent severity methods, findings analytics, and lessons learned.

Maturity should improve efficiency without converting audits into checklist exercises detached from system context.

Chapter 32 — Manual release boundary

Before this manual is published, the controlled English master, authoritative-source verification, technical/editorial review, es-419 and pt-BR semantic review, graphics/accessibility review, DOCX/PDF and page QA, provenance, repository/security audit, and Final Human Release Approval must be complete.

Material content changes after human approval reopen the affected review gates.